Services critiques et coût d'un arrêt de paiement

> ***Statut : cible.*** *Ce document décrit ce que l'équipe vise et a décidé, pas ce qui est déjà codé. L'état réel du code est suivi dans `constat/etat-implementation.md`.*

> *Ticket : WOR-68 · Responsable : Cédric · Version 0.1 du 19/10/2026*
>
> *Ce document sert d'entrée à l'EBIOS RM (échelle de gravité, voir `ebios-rm.md`), aux objectifs RTO/RPO (WOR-70) et au PCA/PRA (WOR-71).*

Hypothèses sur l'entreprise fictive

Tous les chiffres sont **fictifs**. Ils sont choisis pour donner des ordres de grandeur réalistes à un opérateur de paiement de taille moyenne.

Paramètre	Valeur retenue	Commentaire
Transactions par jour	1 200 000	Soit environ 830 par minute en moyenne
Montant moyen d'une transaction	45 €	Paiement de détail
Flux traité par jour	54 M€	1 200 000 × 45 €
Commission moyenne	0,8 %	Revenu de l'opérateur sur chaque transaction
Revenu par jour	432 k€	Soit environ 158 M€ par an
Facteur des heures de pointe	× 2,5	12 h–14 h et 18 h–20 h
Taux d'abandon définitif pendant un arrêt	40 %	Les autres transactions sont rejouées après la reprise
Commerçants partenaires	200	Liés par un contrat de niveau de service
Engagement de disponibilité (SLA)	99,9 % par mois	Soit 43 minutes d'arrêt tolérées par mois
Pénalité en cas de dépassement du SLA	5 % de la facture mensuelle	Environ 650 k€ si tous les partenaires sont touchés

Coût d'un arrêt du traitement des paiements

Perte directe par minute

	Moyenne	Heure de pointe
Transactions bloquées par minute	830	2 080
Flux bloqué par minute	37 500 €	93 750 €
Revenu bloqué par minute	300 €	750 €
Revenu perdu définitivement par minute (40 % d'abandon)	**120 €**	**300 €**

La perte directe reste modeste. **Le vrai coût vient des effets de seuil** : la pénalité contractuelle, l'obligation réglementaire et la perte de confiance.

Coût selon la durée (incident en heure de pointe)

Durée de l'arrêt	Perte directe	Effets de seuil	Coût total estimé	Gravité EBIOS
≤ 5 min	1 500 €	Aucun	~1,5 k€	G1 mineure

Durée de l'arrêt	Perte directe	Effets de seuil	Coût total estimé	Gravité EBIOS
5 à 30 min	jusqu'à 9 k€	Hausse des appels au support	~10 k€	G2 significative
30 min à 2 h	jusqu'à 36 k€	Budget SLA mensuel de 43 min dépassé, donc pénalité d'environ 650 k€ ; incident probablement majeur au sens de DORA (critère économique)	~700 k€	G3 grave
> 2 h	36 k€ et plus	Pénalité SLA, incident **majeur au sens de DORA** (notification à l'ACPR), départ estimé de 0,5 % des partenaires (environ 790 k€ par an)	> 1,5 M€	G4 critique

> *Le seuil DORA de 2 h d'interruption d'un service critique vient des critères de classification des incidents (règlement délégué (UE) 2024/1772). Ce n'est pas le seul critère : dès que la pénalité SLA est déclenchée, l'impact économique dépasse 100 k€ et, avec les partenaires touchés, l'incident devient probablement majeur* ***dès la tranche 30 min à 2 h****. Le détail est dans* `nis2-dora.md` *(WOR-69).*

À retenir : l'arrêt coûte peu tant qu'il dure moins de quelques minutes, puis le coût explose. C'est l'argument central en faveur de la reprise automatique : une reprise manuelle (30 min et plus, d'après le contexte du sujet) fait basculer l'incident en G3, alors qu'une reprise automatique en quelques minutes le maintient en G1.

Services critiques par ordre de priorité

Rang	Service	Criticité	Pourquoi	Dégradation acceptable
1	Traitement des transactions (API de paiement et base de données)	**Vitale**	Porte directement le revenu et l'engagement envers les partenaires	Aucune
2	Authentification	**Vitale**	Sans elle, aucune transaction ne peut être initiée. Intégrée à l'API, avec des sessions stockées en base : elle tombe avec la base (dans le socle au 20/10, sessions en mémoire, perdues à chaque redémarrage)	Aucune
3	WAF / point d'entrée	**Vitale**	Point de passage unique de tout le trafic	Un contournement temporaire n'est **pas** acceptable (exposition directe)
4	Journalisation et SIEM	Importante	Aucun revenu en jeu, mais elle est indispensable à l'investigation et à la conformité	Arrêt de quelques heures, **sans perte** de journaux
5	Consultation de l'historique	Importante	Gêne pour les partenaires, sans perte de revenu	Mode dégradé possible (lecture différée)
6	Supervision, détection ML, moteur de remédiation	Support critique	N'est pas un service métier, mais conditionne la reprise de tous les autres	Arrêt de courte durée, avec retour à une surveillance manuelle
7	Assistant RAG	Non critique	Aide les opérateurs ; le service rendu aux clients n'en dépend pas	Indisponibilité acceptable

Ce qu'on protège en priorité

1. **La continuité du traitement des paiements** (rangs 1 à 3) : la reprise automatique doit viser un retour en service en moins de 5 minutes.
2. **L'intégrité des transactions déjà validées** : une transaction confirmée ne doit jamais être perdue ni dupliquée. Une transaction perdue coûte bien plus cher qu'une minute d'arrêt (litiges, écritures comptables fausses).
3. **La conservation des journaux** : sans eux, impossible d'expliquer l'incident au régulateur ni d'améliorer la détection.

Pistes pour les RTO / RPO

> *Objectifs arrêtés, répartition du RTO sur la chaîne de reprise et protocole de mesure : voir `rto-rpo.md` (WOR-70).*

Service	RTO proposé	RPO proposé
Traitement des transactions	≤ 5 min	0 (aucune transaction validée perdue)
Authentification	≤ 5 min	Sans objet : une session perdue oblige seulement à se reconnecter
Journalisation	≤ 1 h	0
Consultation	≤ 30 min	0
Assistant RAG	Meilleur effort	Sans objet